Probaho — Security self-assessment

Draft PDF generated from docs/SECURITY_SELF_ASSESSMENT.md; this is not a certification.

Permission tiers

agent_read; agent_propose; human_approval; sandbox_execute; user_write; denied. Approval and execution are absent from the model tool surface.

Core controls

Business scoping, integer-paisa arithmetic, whole-file import validation, snapshot hashes, policy limits, expiry and nonce, payee/date/amount rechecks, explicit synthetic supplier consent, idempotent execution, and post-commit read-back.

Abuse cases

Prompt injection, cross-business IDs, direct execution, missing/rejected consent, changed payee, changed amount/date, expired approval, replay, stale balance, payroll deferral, policy overflow, mixed currency, malformed CSV, formula export, and cross-site writes.

Residual risk

The local database is unencrypted and rewritable, the operator is not multi-user authenticated, the hash chain is not externally notarized, and model output remains probabilistic. No real-money capability is connected.

Release gate

Disable execution until unauthorized mutation is zero, deterministic calculations reconcile, reminders remain zero-cash, mock financing is non-executable, changed approvals fail, read-back exists, and the evidence chain verifies.